API SECURITY TESTING

Exploiting an unused API endpoint

PortSwigger Web Security Academy Lab Report

Platform:	PortSwigger Web Security Academy
Tool:	Burp Suite Community Edition
Category:	API Testing
Status:	Completed

Practical testing performed in an authorized training environment.

Contents

1 Objective

Find and use an API endpoint that is not directly exposed through the normal application interface, then test whether it allows an unintended change to product pricing.

2 Methodology

1. Inspected the application's requests and responses using Burp Suite while interacting with the shopping functionality.
2. Identified the product price API route: PATCH /api/products/1/price.
3. Tested the endpoint and observed that the server expected the request body to use the application/json content type. A request with an unsupported content type returned HTTP 400 and an explanatory error.
4. Resent the request using Content-Type: application/json and a JSON body setting the price to 0.
5. The server accepted the request and returned HTTP 200 OK with the updated price shown as $0.00.
6. Added the lightweight leather jacket to the cart and confirmed that its displayed price and order total were $0.00.
7. Placed the order and confirmed that the lab displayed its successful completion message.

3 Finding and Result

The application exposed a price-update API endpoint that could be called directly. The endpoint accepted a client-supplied price of zero and updated the product price, allowing the item to be ordered at no cost in the lab.

4 Potential Impact

If a customer can change product prices through an exposed API, this can lead to financial loss, unauthorized price changes and manipulation of orders. The demonstrated impact was limited to the lab environment.

5 Recommendations

- Do not allow ordinary customers to set product prices. Prices should be calculated and controlled by trusted server-side business logic.
- Enforce role-based authorization for price-management operations.
- Validate product updates against server-side business rules and trusted data.
- Ensure the order total is recalculated and verified on the server, rather than trusted from client-controlled values.
- Monitor and audit changes to product pricing.

6 Evidence

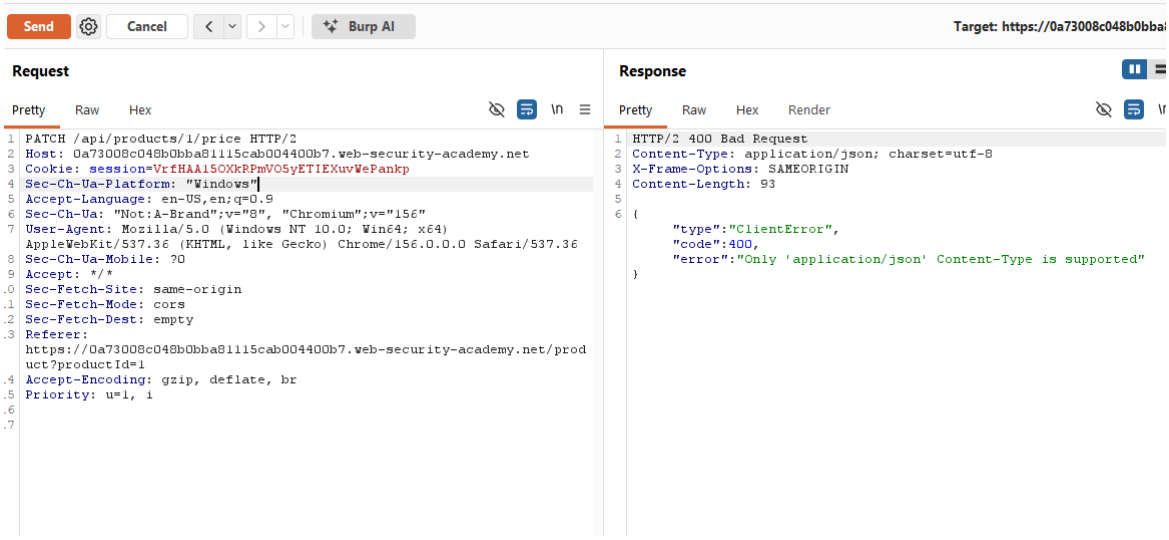


Figure 1: Burp Suite request and response showing the endpoint and the initial content-type validation error.

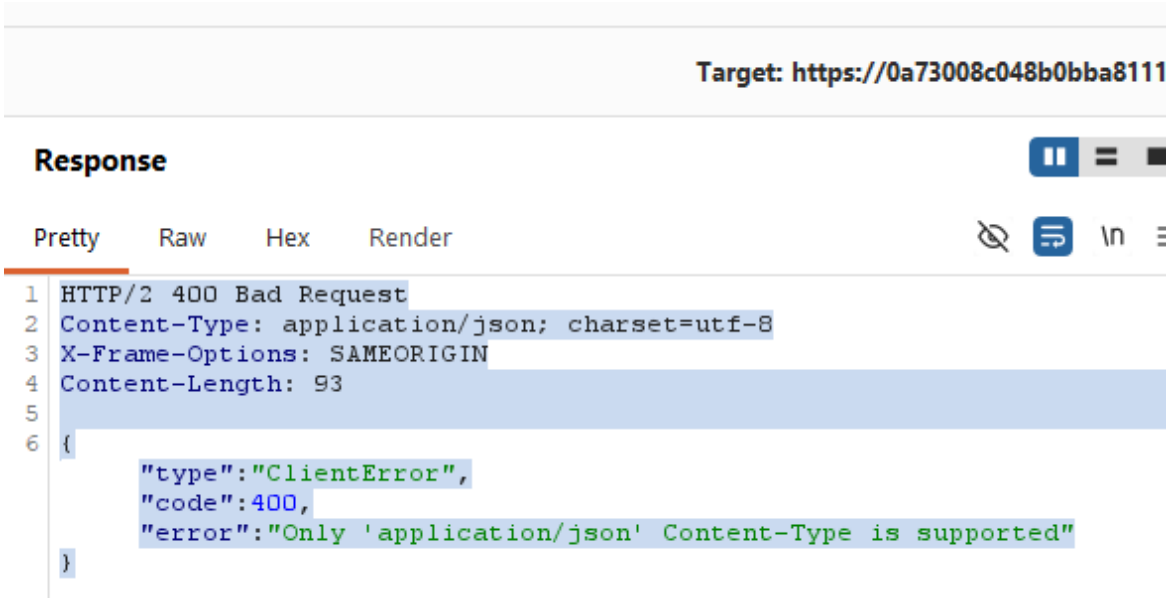


Figure 2: Server response explaining that application/json is the supported content type.

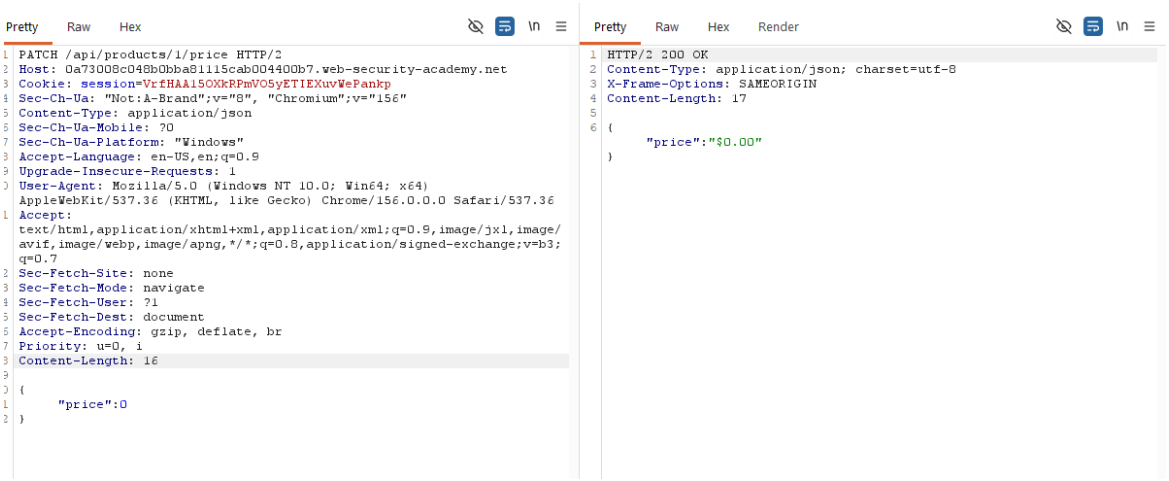


Figure 3: PATCH request with a JSON price value of zero and the successful response.

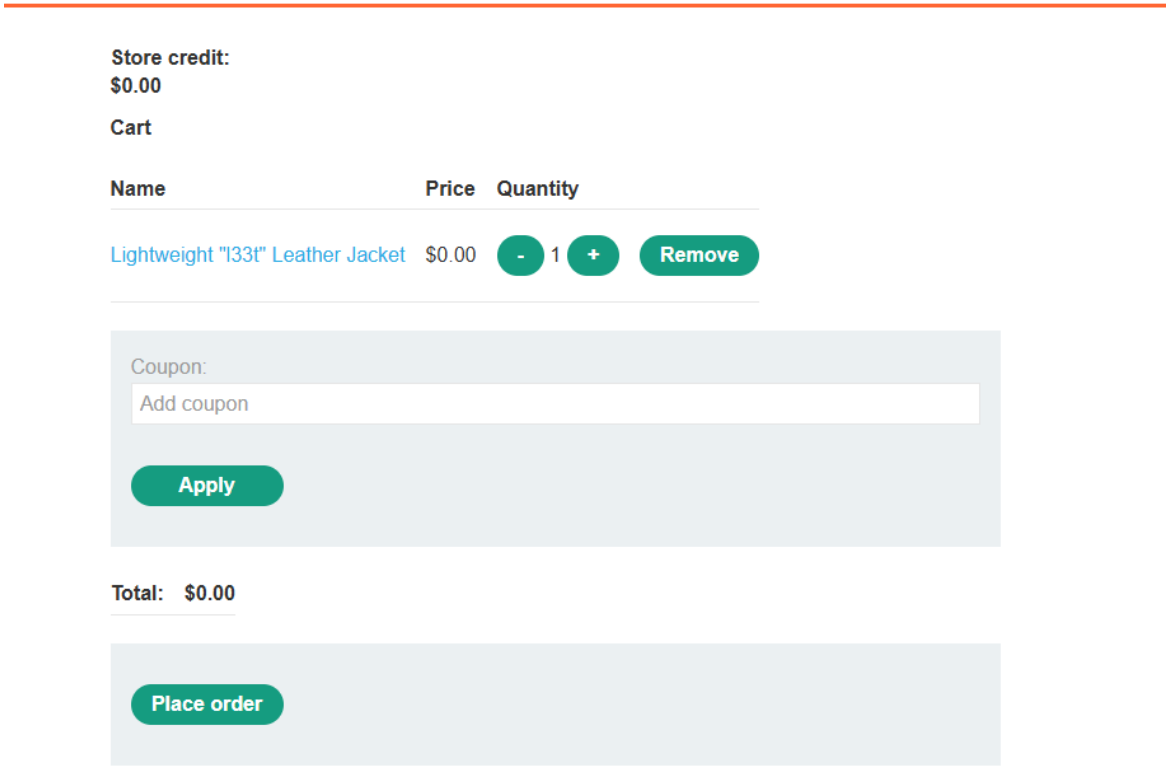


Figure 4: Shopping cart showing the jacket and order total at $0.00.

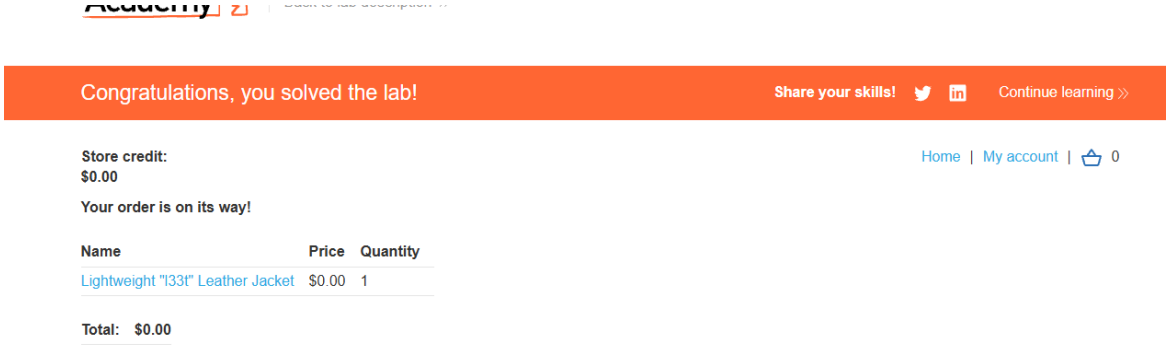


Figure 5: PortSwigger confirmation that the lab was solved.

7 Conclusion

The exercise showed that an API endpoint can remain callable even when the normal interface does not provide a way to use it. It also demonstrated the business risk of trusting client-supplied values for sensitive operations such as product pricing.

Disclaimer: All testing was conducted in the authorized PortSwigger Web Security Academy lab environment.